THE FINAL COMPLIANCE DOSSIER

Legal & Ethical Implementation

DeRexi: Policy Pilot / Compliance 1 — Assignment 5

EXECUTIVE SUMMARY

The fifth compliance assignment brings together a regulatory-obligations matrix, an eight-step ethical decision framework, three applied tabletop scenarios, a quantified 12-risk register, and an incident-response procedure. The technical update also repairs incident guidance and strengthens escalation-state controls.

112 / 112	4 / 4	12
TARGETED TESTS PASSED	RUBRIC AREAS DOCUMENTED	RISKS SCORED

Implementation result. Seventeen new controls/compatibility tests passed; all nine original incident regressions now pass. The previously failing four incident-guidance cases were resolved without altering their original assertions.

Assurance boundary. Tests use isolated/synthetic environments. The ordinary compatibility entry point remains unguarded; Messages, production sign-in, real PostgreSQL integration, TLS deployment, immutable audit records, and approved retention controls remain outstanding.

Prepared 05 November 2026 | Development baseline c4641b5

Fictional institution: Aurum Capital Bank. This is a classroom implementation report, not a legal compliance certification.

01 / REGULATORY CONTEXT

Obligations & governance

Regulatory applicability depends on Aurum Capital Bank's actual charter, regulator, activities and data. The following matrix is a conditional assessment; exact legal applicability and currency were not independently verified because official reference hosts were blocked in the Codex environment.

Ref / status	Source and expected control	DeRexi application mapping
O01–O02 / conditional law	GLBA 15 USC §§6801(b), 6802; applicable implementing and privacy rules require counsel review.	Protect customer information; assess private record disclosures and AI-provider handling.
O03–O04 / guidance	FFIEC IT Examination Handbook: access control, incident response and oversight.	Role-scoped access; classify, assign, escalate and review incidents.
O05–O07 / framework	NIST CSF 2.0: PR.AA, PR.DS, DE.CM, RS.MA, RS.CO.	Identity and authorization, protection/monitoring, incident management.
O08–O09 / control catalog	NIST SP 800-53 Rev. 5: AC-3, AC-6; AU-2, AU-3, AU-6, AU-9, AU-11.	Least privilege plus meaningful, protected and retained event records.
O10 / framework	NIST CSF GV.SC; SP 800-53 SR-3/SR-6, IR-4/IR-6.	Third-party feeds, source attribution and review/escalation decisions.

Key regulatory distinction

GLBA and applicable implementing rules may be binding. FFIEC publications are supervisory guidance. NIST CSF and SP 800-53 are voluntary frameworks/control catalogs unless separately adopted or mandated. The FTC Safeguards Rule should not automatically be assumed to govern a federally chartered bank.

Current safeguards support parts of these objectives, but tested application controls do not establish compliance with an entire statutory or regulatory obligation.

02 / ETHICAL GOVERNANCE

Decisions with accountability

Proposed eight-step decision process

01 Recognize the questionable action or disclosure.

02 Identify stakeholders and data subjects.

03 Consult relevant policy, rules and authorized roles.

04 Assess confidentiality, fairness, accuracy and potential harm.

05 Compare limited action, inaction and escalation.

06 Escalate ambiguity to the appropriate accountable function.

07 Record rationale, evidence and responsible reviewer.

08 Review outcome, correction and recurrence.

Three applied tabletop decisions

Case	Ethical problem	Preferred response / owner
ETH-A	Employee requests another person's private clarification or incident.	Deny private access without revealing content; route a new concern. Assigned owner/handler; security for account misuse.
ETH-B	Policy Assistant omits a material exception or offers incomplete guidance.	Review the cited version, flag feedback, request clarification and pause consequential action. Policy Owner + compliance.
ETH-C	Pulse article has uncertain authenticity or applicability.	Verify official source, dates and institutional scope before policy changes. Policy Owner + compliance/legal.

These scenarios are synthetic tabletop analyses. Relevant API privacy/reference checks were executed, but the tabletop decisions were not live employee events or operationally approved processes.

03 / RISK ASSESSMENT

Twelve prioritized risks

The planning method uses Likelihood (1–5) × Impact (1–5). Bands: Low 1–4; Moderate 5–9; High 10–16; Critical 17–25. These are illustrative prioritization estimates, not measured incident likelihoods or accepted operational risks.

ID	Risk scenario	L × I	Band
R01	Unauthorized access / impersonation	15	High
R02	Unguarded compatibility application	20	Critical
R03	Sensitive information disclosure	15	High
R04	Messages workflow unavailable/insecure	12	High
R05	Incorrect retrieval or citation	12	High
R06	Delayed clarification escalation	9	Moderate
R07	Missing approval and audit events	16	High
R08	Retention and legal-hold gaps	16	High
R09	Regulatory attribution or staleness	8	Moderate
R10	Unverified deployment / TLS	15	High
R11	Incident defects / outages	12	High
R12	Inadequate compliance monitoring	9	Moderate

Release-blocking priorities

R02: Isolate the unguarded compatibility entry point and validate the secured production factory. R10: verify authenticated sign-in and HTTPS/TLS in approved staging before any real-data deployment. Residual risk scores in Codex’s detailed register assume mitigations succeed; they are not verified.

04 / INCIDENT OPERATIONS

From reporting to resolution

Proposed classification & response standards

Severity	Illustrative scenario	Proposed internal target
Low	Contained documentation issue	Acknowledge within 2 business days
Medium	Incomplete guidance / limited impact	Acknowledge within 1 business day
High	Suspected disclosure or account misuse	Acknowledge within 1 staffed hour
Critical	Active compromise or severe ongoing harm	Escalate immediately; aim for 15 minutes

These are proposed internal response targets, not statutory notification deadlines, implemented timers, or approved staffing commitments.

Incident workflow

Detection → Intake → Classification → Assignment → Containment → Investigation → Escalation → Corrective action → Resolution → Follow-up → Evidence retention

Stage	Responsible function / evidence
Intake and triage	Employee files case; handler records facts, category, severity and affected service.
Assignment and investigation	System Administrator assigns; handler collects minimal necessary evidence and preserves originals.
Escalation and containment	Administrator authorizes escalation and privileged case changes; legal/privacy reviews possible disclosure.
Resolution and follow-up	Handler documents corrective action; escalated closure requires administrator; compliance verifies recurrence controls.
Retention and notification	Records custodian applies legally reviewed holds/disposition. Legal/compliance determines any external reporting duty.

Operational limitation

The application stores basic incident fields and mutable notes, but does not yet provide an immutable status-transition log, structured legal-notification decision, acceptance timestamps, legal holds, or an approved emergency fallback.

05 / TECHNICAL EVIDENCE

Implemented. Tested. Bounded.

What changed in the application

- Restored incident guidance: incident creation returns approved-policy references and a human-review notice; no new AI call is made.
- Enforced state transitions: reported → triaged/escalated; triaged → escalated/resolved; escalated → resolved; resolved is terminal. Invalid combinations are rejected.
- Restricted escalated-case closure: System Administrator authority is required for status/level changes once escalated; assigned handlers can still add notes and severity.
- Prevented partial writes: invalid transitions and search failures are handled before persistence, with safe errors.

Targeted verification — 05 Nov 2026

Suite	Passed	Failed
New Assignment 5 controls / compatibility	17	0
Original incident regression tests	9	0
Secured / local-demo API tests	32	0
Input validation hardening	28	0
Original C-02 security controls	26	0
TOTAL	112	0

Previously failing incident-guidance checks now pass in the original nine-case suite. This is local isolated testing: no live database writes, production deployment or actual customer information. The historical C-01 15/15 and C-03 55/55 results were reused, not rerun in this Assignment 5 execution.

06 / REMEDIATION & RELEASE

What remains to close

Priority	Outstanding dependency	Acceptance evidence
P0	Secure deployment entry point and real authenticated user journey; HTTPS/TLS.	Staging sign-in/denial tests, proxy and transport verification.
P1	Messaging endpoint and clarification workflow; operational response plans.	Participant-only browser/API tests; tabletop and fallback evidence.
P1	Approval history, retention, legal hold and evidence integrity.	Reviewed event schema, atomicity, hold/disposal/restore tests.
P1	Policy-version accuracy, privacy and AI-provider suitability.	Approved version test corpus; privacy and data-handling review.
P1	Live regulatory feeds and current official legal references.	Authorized read-only source checks; legal applicability sign-off.
P2	Dashboard metric presentation and trend/reporting quality.	Metric edge-case assertions and reviewed management reports.

Rubric completion statement

- Legal obligations: ten-entry matrix with source classifications and implementation mapping.
- Ethical decisions: eight-step framework and three worked tabletop scenarios.
- Risk assessment: twelve risks with defined 5×5 scoring and proposed mitigation priorities.
- Incident procedures: classification, reporting, escalation, investigation, resolution and follow-up.

All four documentation requirements are addressed. Operational adoption, legal review, production authentication, deployment and records-enforcement claims remain outside the verified scope.

07 / REFERENCES & EVIDENCE

Evidence provenance

Source of record: Codex's assignment5_legal_ethical_implementation.md, dated 05 November 2026, baseline commit c4641b5 on branch codex/derexi-security-hardening. This publication is a curated management-facing summary; the original Markdown and generated JSON/logs retain detailed scenario and line-level evidence.

Evidence	Repository reference / significance
E1 · Current test run	docs/compliance/evidence/assignment5_2026-11-05T212025135075Z/verification_results.json; paired per-suite JSON and logs; 112 PASS.
E2 · Security baselines	docs/compliance/assignment3_security_hardening_final.md and 05 Nov source hashes, C-01 / C-03 results, browser outcomes.
E3 · Auth / RBAC design	docs/security-entrypoints.md; docs/rbac-design-review.md; docs/development-known-issues.md.
E4 · Governance baseline	docs/compliance/assignment4_gap_analysis.md; docs/database-design.md; existing Python handlers and models.
E5 · Source-access limitation	docs/compliance/evidence/assignment5_2026-11-05T212025135075Z/source_access_status.json; four official-source checks blocked.
S1–S4 · Official reference locators	FTC GLBA materials; FFIEC IT Examination Handbook; NIST CSF 2.0 (CSWP 29); NIST SP 800-53 Rev. 5. Official current text not fetched by Codex.

Final assurance boundaries

- No real Supabase data, identities, grants, RLS, schema migrations or public deployments changed in this work.
- No current legal citation/currency verification, operational incident exercise, production PostgreSQL, verified TLS or live Pulse tests.
- No immutable business audit history, approved retention/disposal process, or production browser sign-in was established.
- The previously reported missing Messages endpoint may be addressed by separate Codex work currently in progress; this report does not claim its resolution.

DE REXI / GOVERNANCE WITH EVIDENCE

Prepared for the final Compliance 1 rubric submission.